NAVIOTECH SOLUTION PVT LTD

Minor Project 1

Cybersecurity Risk Assessment Framework for Small Businesses

PREPARED BY

Shrish Tyagi

DATE

September 2026

1. Introduction

Small and medium enterprises (SMEs) increasingly rely on digital tools for sales, communication, and record-keeping, yet most operate without a dedicated IT security team or a formal way to measure their risk exposure. Attackers are aware of this gap and frequently target SMEs precisely because their defenses are weaker than those of large corporations. This project builds a simple, practical risk assessment framework that any small business can use to identify its most pressing cybersecurity risks and select mitigation steps that fit its size and budget.

2. Objectives

- Develop a model for evaluating cybersecurity risks in small and medium enterprises (SMEs).
- Propose mitigation strategies to enhance their security posture.
- Design and validate network topology architecture using Cisco Packet Tracer for practical implementation.

3. Cisco Packet Tracer Network Topology

To support practical infrastructure assessment, the cybersecurity risk framework incorporates a centralized network topology designed and simulated in Cisco Packet Tracer. The architecture features a primary Router (2911 Router0) connected to a central Switch (2960 Switch0), serving enterprise servers (Server0, Server1) and end-user workstations (PC2, PC3, Laptop0).

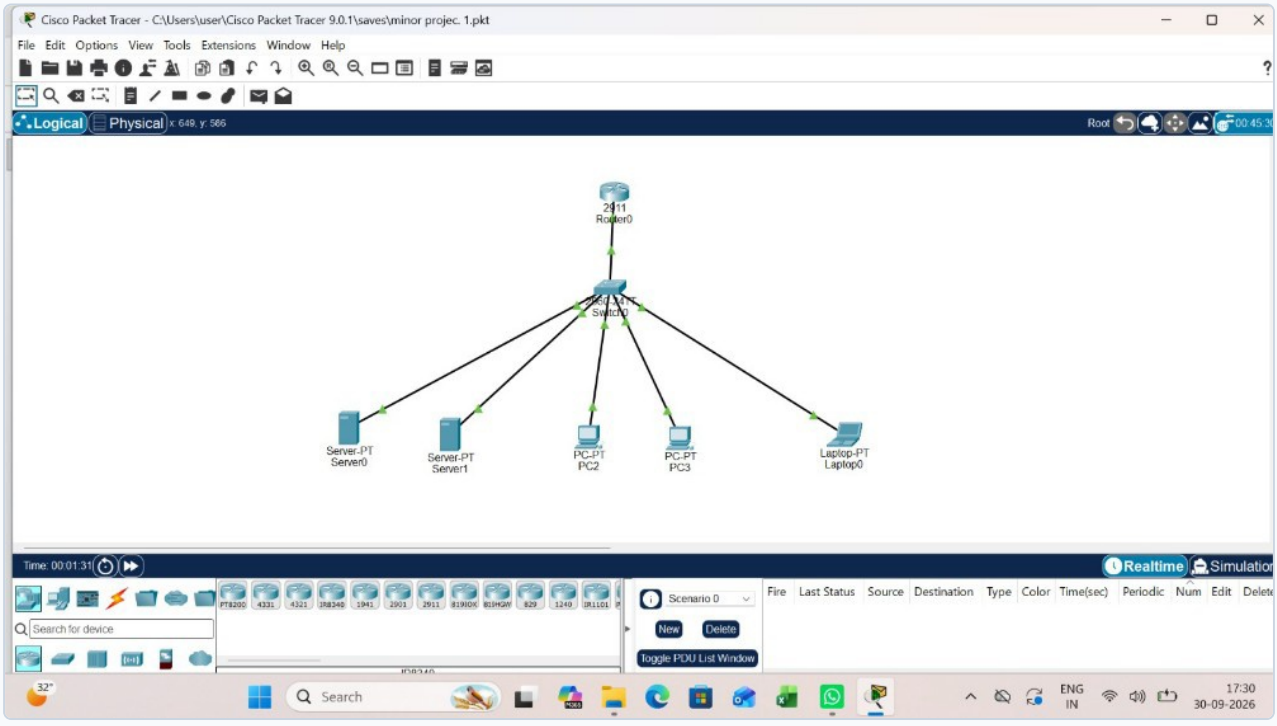


Figure 1: Cisco Packet Tracer Network Topology Simulation for SME Security Assessment

4. Common Cybersecurity Risks in SMEs

Research into SME security incidents consistently points to a small set of recurring risks. These form the basis of the assessment model:

- **Phishing:** Fraudulent emails or messages that trick employees into revealing credentials or installing malware. This remains the most common entry point for attackers because it targets people rather than technology.
- **Ransomware:** Malicious software that encrypts business data and demands payment for its release, often arriving through a phishing link or an unpatched system vulnerability.
- **Insider threats:** Misuse of access by employees or contractors, whether malicious or accidental (e.g., mishandling customer data).
- **Weak or reused passwords:** Credentials that are easy to guess or shared across multiple accounts, making a single breach easy to escalate.
- **Unpatched software:** Outdated operating systems or applications with known vulnerabilities that attackers actively scan for.
- **Unsecured remote access and Wi-Fi:** Poorly configured networks that let attackers intercept traffic or gain unauthorized entry.
- **Lack of data backups:** No reliable way to recover data after an incident, which turns a minor breach into a business-ending event.

5. Risk Assessment Model

The framework is structured around the NIST Cybersecurity Framework (CSF), which organizes security activity into five functions: **Identify, Protect, Detect, Respond, and Recover**. This structure was chosen because it is vendor-neutral, widely recognized, and scales down well to organizations without dedicated security staff.

- **Identify:** Catalog business assets (devices, data, accounts) and the risks that threaten them.
- **Protect:** Put safeguards in place, such as access controls and staff training.
- **Detect:** Establish ways to notice when something has gone wrong (e.g., unusual login activity).
- **Respond:** Define steps to take once an incident is confirmed.
- **Recover:** Plan how the business restores normal operations, including from backups.

6. Risk Evaluation Metric

Each risk is rated on two dimensions, Likelihood and Impact, both on a scale of 1 (very low) to 5 (very high). The **Risk Score = Likelihood × Impact** (range 1–25). Scores of 15+ are High priority, 8–14 Medium, and below 8 Low.

Threat / Risk	Likelihood (1-5)	Impact (1-5)	Risk Score	Priority
Phishing emails	4	4	16	**High**
Ransomware infection	3	5	15	**High**
Weak / reused passwords	4	3	12	**Medium**
Unpatched software	3	4	12	**Medium**
Insider misuse of access	2	4	8	**Medium**
Unsecured Wi-Fi / remote access	3	3	9	**Medium**
Lack of data backups	2	5	10	**Medium**
No employee security training	4	2	8	**Low**

7. Proposed Mitigation Strategies

1. **Multi-factor authentication (MFA):** Enforce on email and all critical accounts to counter phishing and weak passwords.
2. **Employee security-awareness training:** Short, regular sessions on recognizing phishing attempts and safe password practices.
3. **Automated patch management:** Ensures operating systems and network software receive prompt security updates.
4. **Endpoint protection and firewalls:** Deploy antivirus and robust network firewalls across all devices.
5. **Encrypted, regularly tested backups:** Store backups separately (offline or cloud) to survive ransomware.
6. **Least-privilege access control:** Limit user permissions strictly to necessary job functions.
7. **Simple incident response plan:** Maintain an accessible one-page protocol for suspected breaches.

8. Validation Through Case Studies

Business Profile	Top Risk	Score	Key Recommended Mitigation
Local retail store (POS system, 5 staff)	Phishing targeting owner's email	16	MFA on email + basic staff awareness training
Small accounting firm (10 staff, client data)	Ransomware via unpatched software	15	Automated patching + offline encrypted backups
Small e-commerce business (online store)	Weak/reused admin passwords	12	Password manager + MFA on all admin accounts

9. Findings and Best Practices

Phishing and ransomware consistently scored as highest-priority risks across scenarios. Mitigations with the best cost-to-benefit ratio were MFA and staff security training. Recommended best practices include starting with MFA, automating patches/backups, running periodic risk assessments, and maintaining an executable incident response plan.

10. Conclusion

This project demonstrates that a structured, low-cost risk assessment framework — built on the NIST CSF and simple quantitative scoring — allows small businesses to effectively prioritize cybersecurity risks without requiring dedicated enterprise security teams. Integrating packet tracer network topologies provides a solid foundation for practical implementation.